移动智能系统安全

Mobile Smart System Security

授课教师： 陈恺、孟国柱

第二章 移动安全模型

(第二部分)

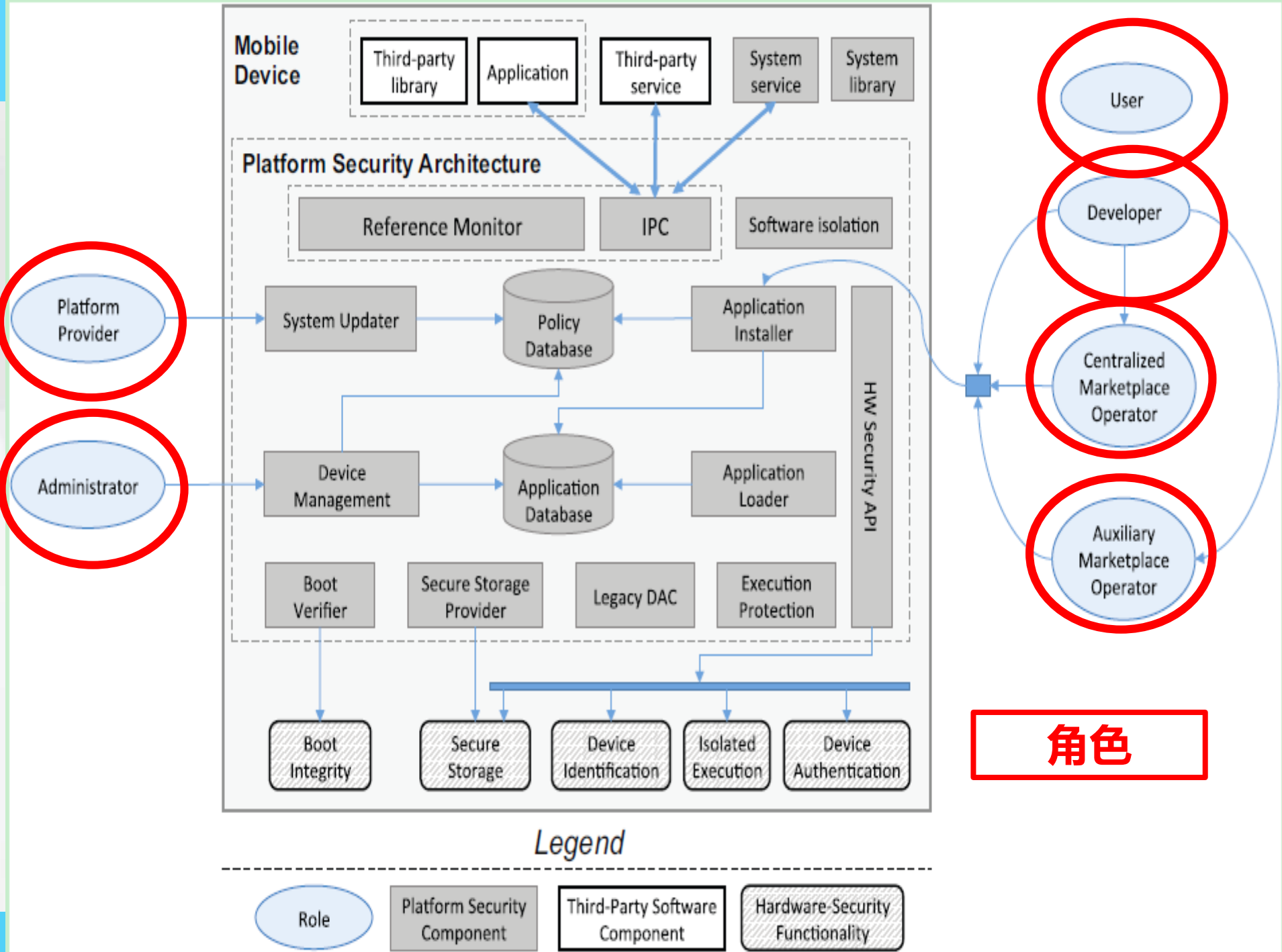
授课教师：陈恺

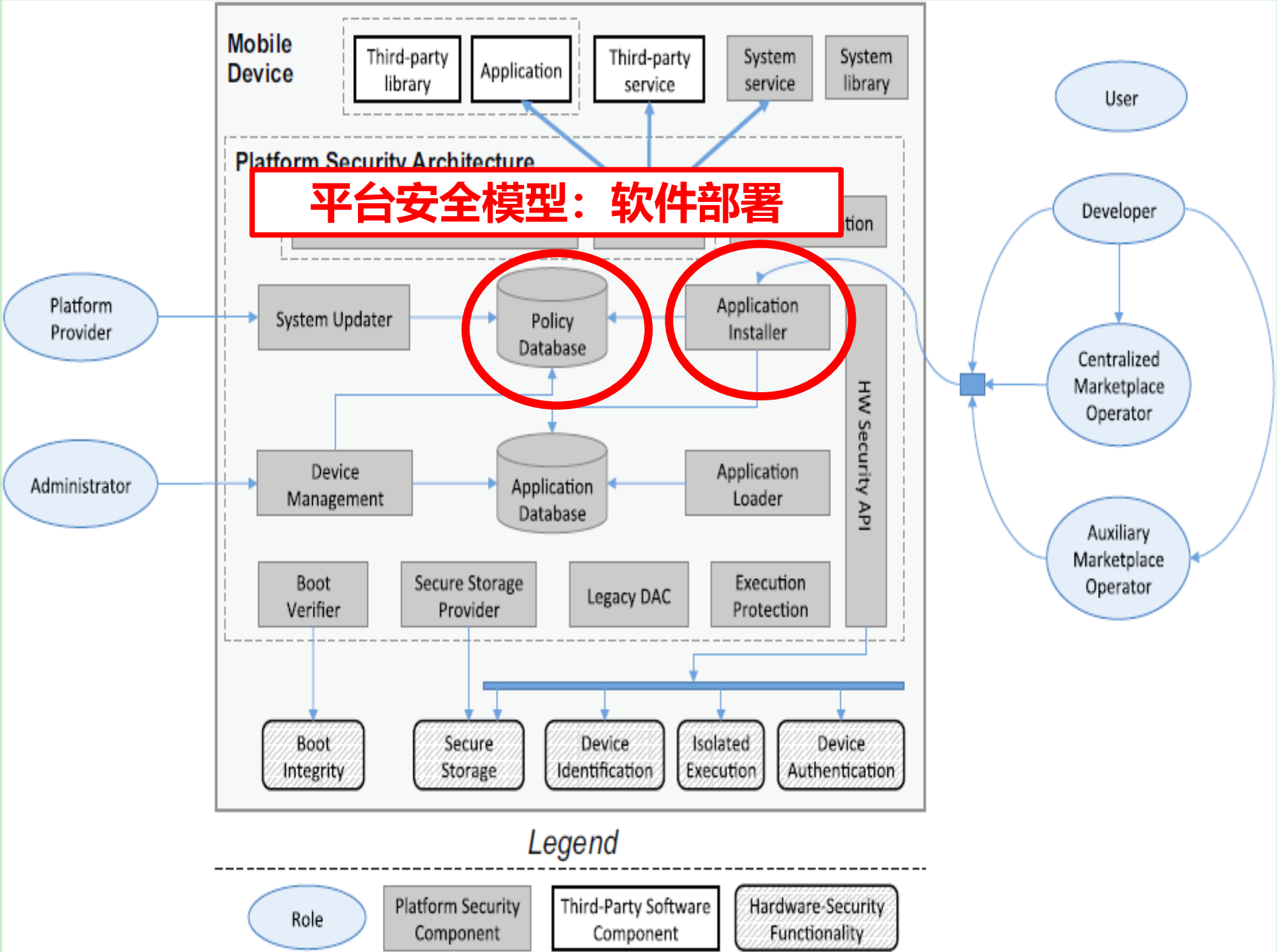
课程目录

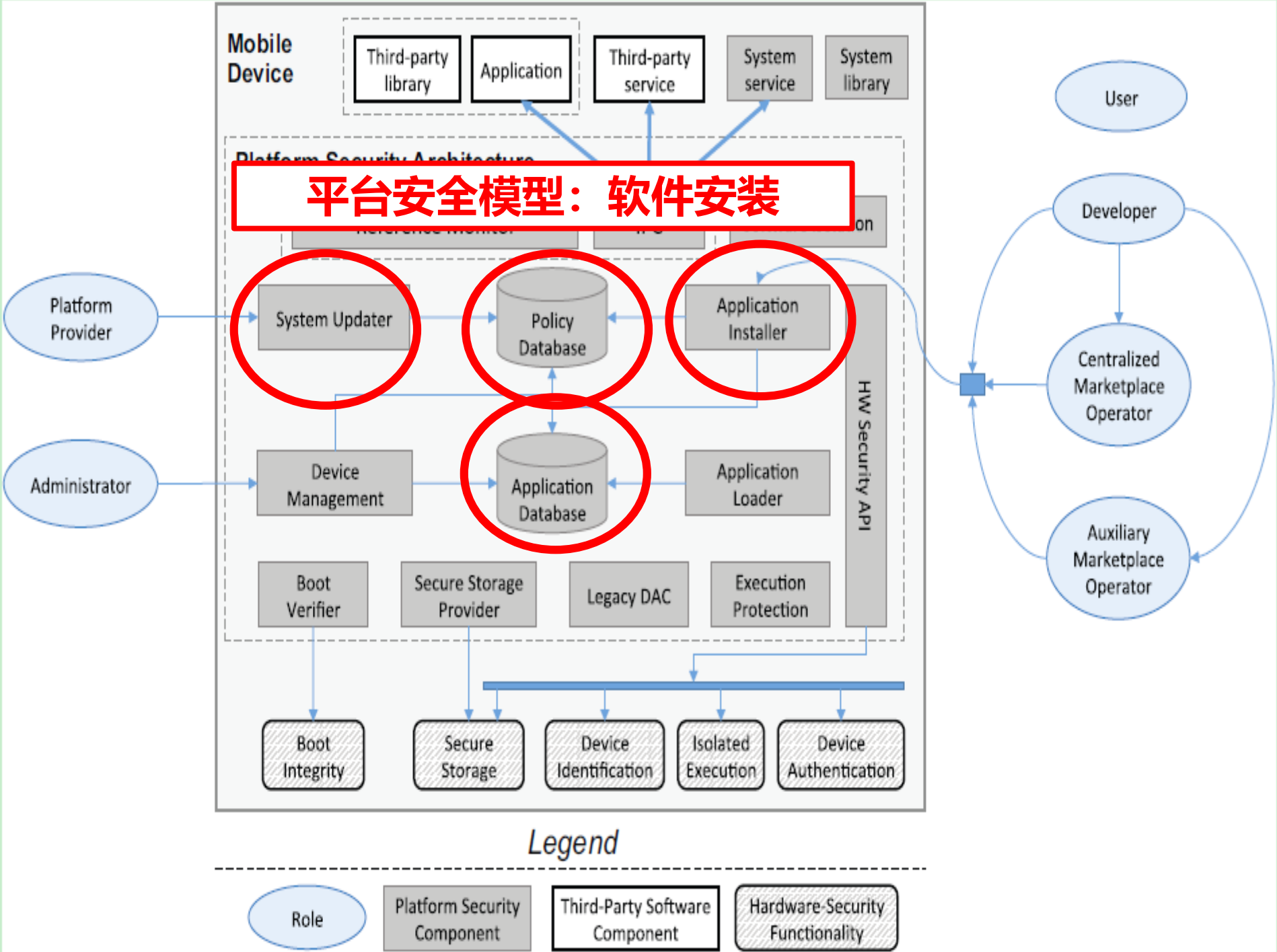
- 第一章 移动安全简介
- 第二章 移动安全模型
- 第三章 移动操作系统与比较
- 第四章 典型移动安全问题与分析
- 第五章 移动安全渗透与反渗透
- 第六章 移动硬件安全与企业拓展
- 第七章 移动智能模型部署安全
- 第八章 移动平台安全前沿研究

回顾上节课

- 2.1 移动设备系统（七个角色）
- 2.2 移动软件架构
- 2.3 平台安全模型
  - 三项原则（隔离性、权限、签名）
  - 2.3.1 软件部署
  - 2.3.2 软件安装


Mobile Device
Third-party library
Application
Third-party service
System service
System library
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Administrator
Device Management
Application Database
Application Loader
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
User
Developer
Centralized Marketplace Operator
Auxiliary Marketplace Operator
角色
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
平台安全模型：软件部署
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Developer
Centralized Marketplace Operator
Auxiliary Marketplace Operator
Platform Provider
Administrator
System Updater
Policy Database
Application Installer
Device Management
Application Database
Application Loader
HW Security API
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality

平台安全模型：软件安装

回顾上节课

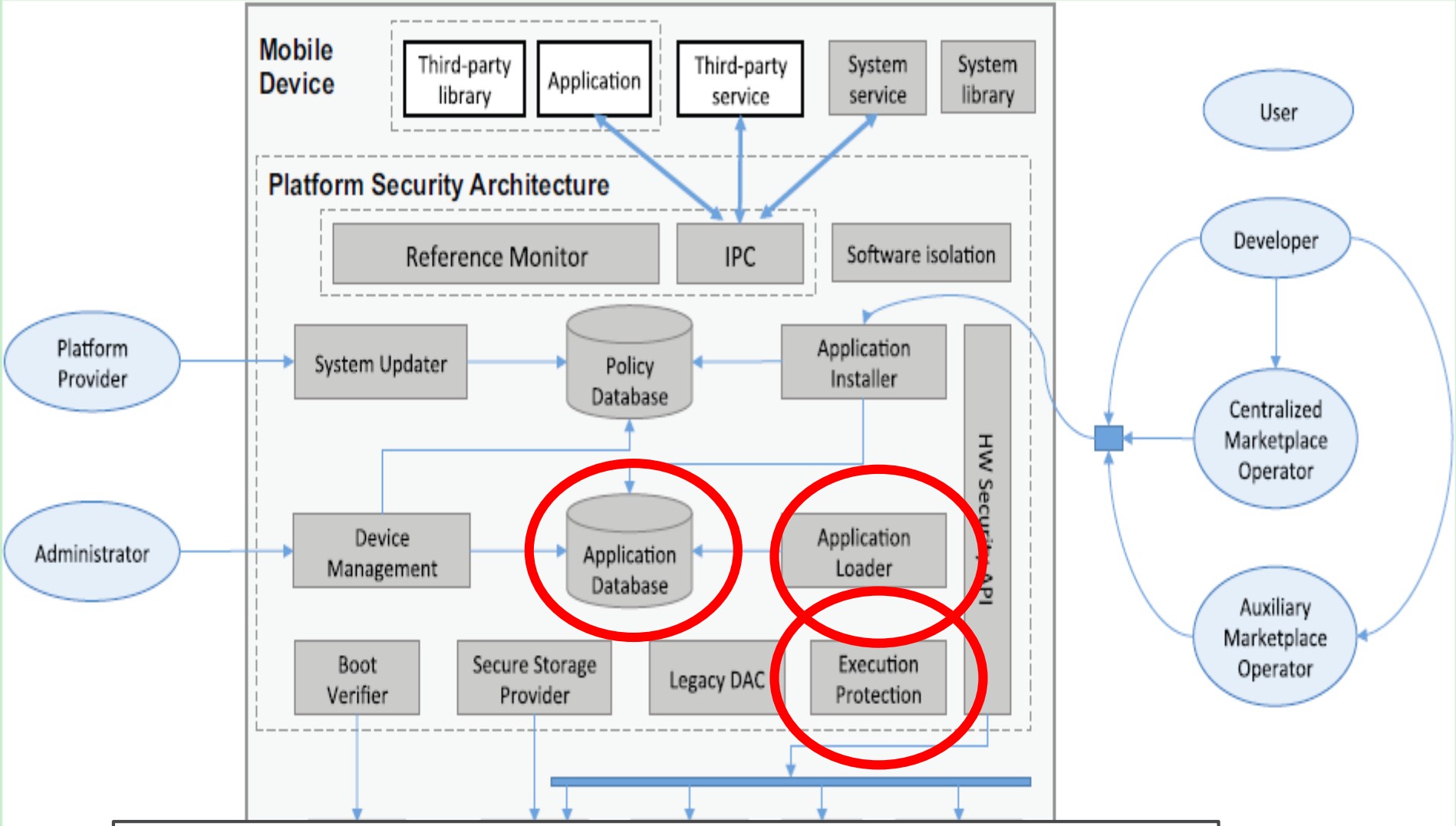
- 2.1 移动设备系统（七个角色）
- 2.2 移动软件架构
- 2.3 平台安全模型
  - 三项原则（隔离性、权限、签名）
  - 2.3.1 软件部署
  - 2.3.2 软件安装
  - 2.3.3 运行时保护
  - 2.3.4 平台管理

2.3.3 运行时保护

- 这部分列举了有关应用运行时保护的平台安全模型概念
- 运行时权限（Runtime permissions）
- 权限强制（Permissions enforcement）
- 执行保护（Execution protection）
- 应用程序数据保护（Application data protection）
- 硬件安全API（Hardware security APIs）

运行时权限（Runtime permissions）

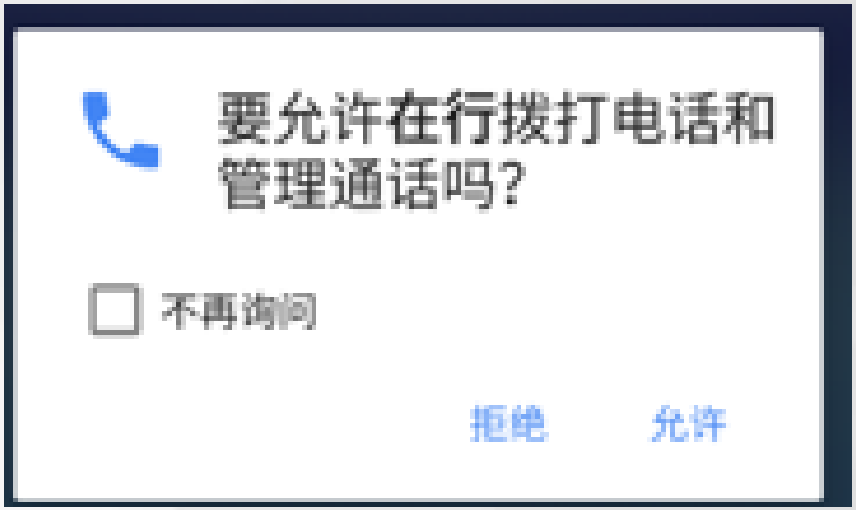
- 目标：获取程序运行过程中应当具有的权限
- 方式：在加载程序或库的时候启用



当运行一个程序或服务部件时，**程序加载器**从**应用数据库**里读取**应用权限和标识符**并与运行进程相关联，加载器同时将**库**与**进程**相连。

权限强制（Permissions enforcement）

- 在运行时，应用函数调用系统服务API和第三方服务API时，被Reference monitor（监控器）安全部件处理过的。监控器附属于移动平台中IPC框架
- 监控器会显示运行时提示（runtime prompt）要求用户准许或拒绝获取运行时被保护IPC调用中需要的权限



权限强制（Permissions enforcement）

- 除了基于权限的强制访问控制，移动平台也会使用当前**传统访问控制策略**（legacy DAC）。例如，基于Linux的移动平台可以使用Linux**用户ID和组ID**还有控制第三方软件获取系统和应用资源的权限。

权限强制（Permissions enforcement）

- 在权限强制的时候也可能会有权限审计（日志记录）
- 能否被绕过?

执行保护（Execution protection）

- 移动平台支持多种运行时**软件隔离**（isolation）和**执行保护**（execution protection）的机制。目的是防止恶意应用篡改代码或控制流，并影响其他进程
- 手段1：不同进程的存储区域必须是分开的
- 手段2：进程地址空间随机化
- 手段3：对于复杂的典型运行攻击来说（例如，缓冲区溢位攻击）专有的存储区域是无法执行的

应用程序数据保护（Application data protection）

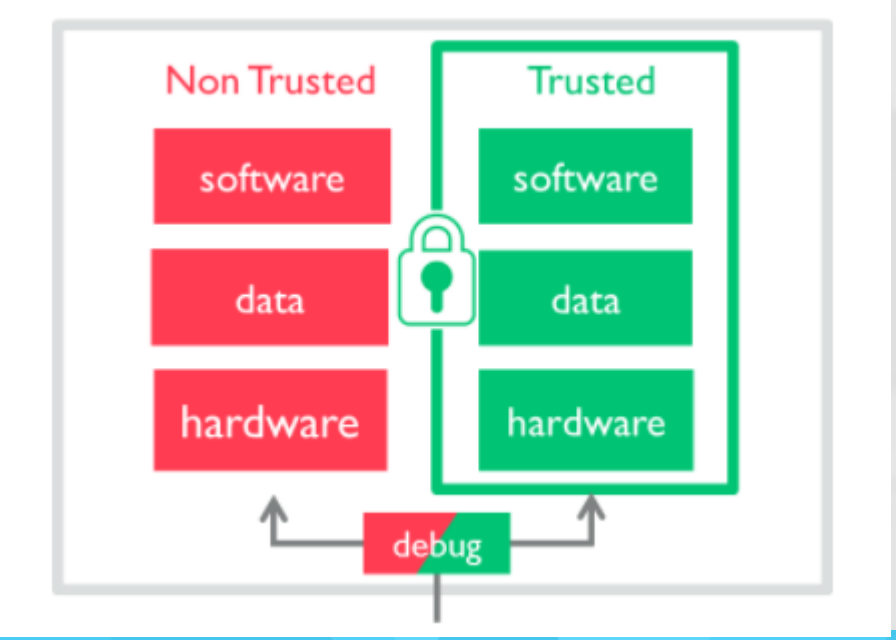
- 移动应用需要长期保护储存的数据。
- 安全的存储功能包含两部分：保护数据**完整性**（integrity）和数据**机密性**（confidentiality）
- 对于能够物理接触到设备的敌手来说，基于软件的数据保护机制是很容易被攻击的

（早期：照片很容易被导出；现在要密码或在手机上允许操作）

- 硬件辅助的安全存储（secure storage）功能

硬件安全API（Hardware security APIs）

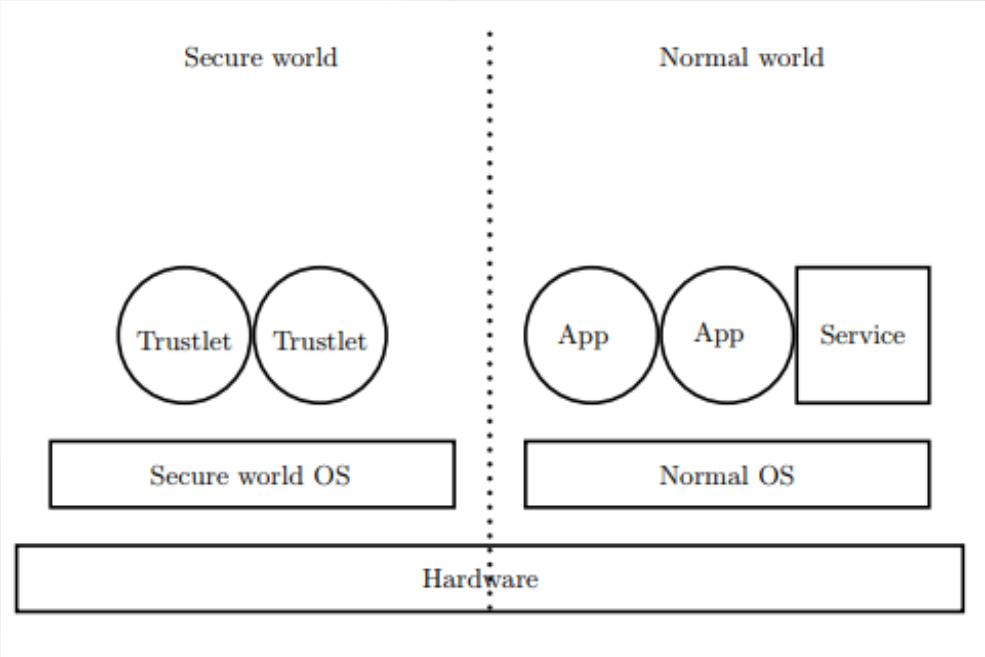
- 基于软件的隔离机制对于平台代码中的执行错误来说是很容易被攻击的
- 安全性关键应用需要硬件辅助的独立执行过程，例如，应用执行不仅与其他移动应用独立，还与移动平台独立
- 硬件安全架构（如：ARM TrustZone）

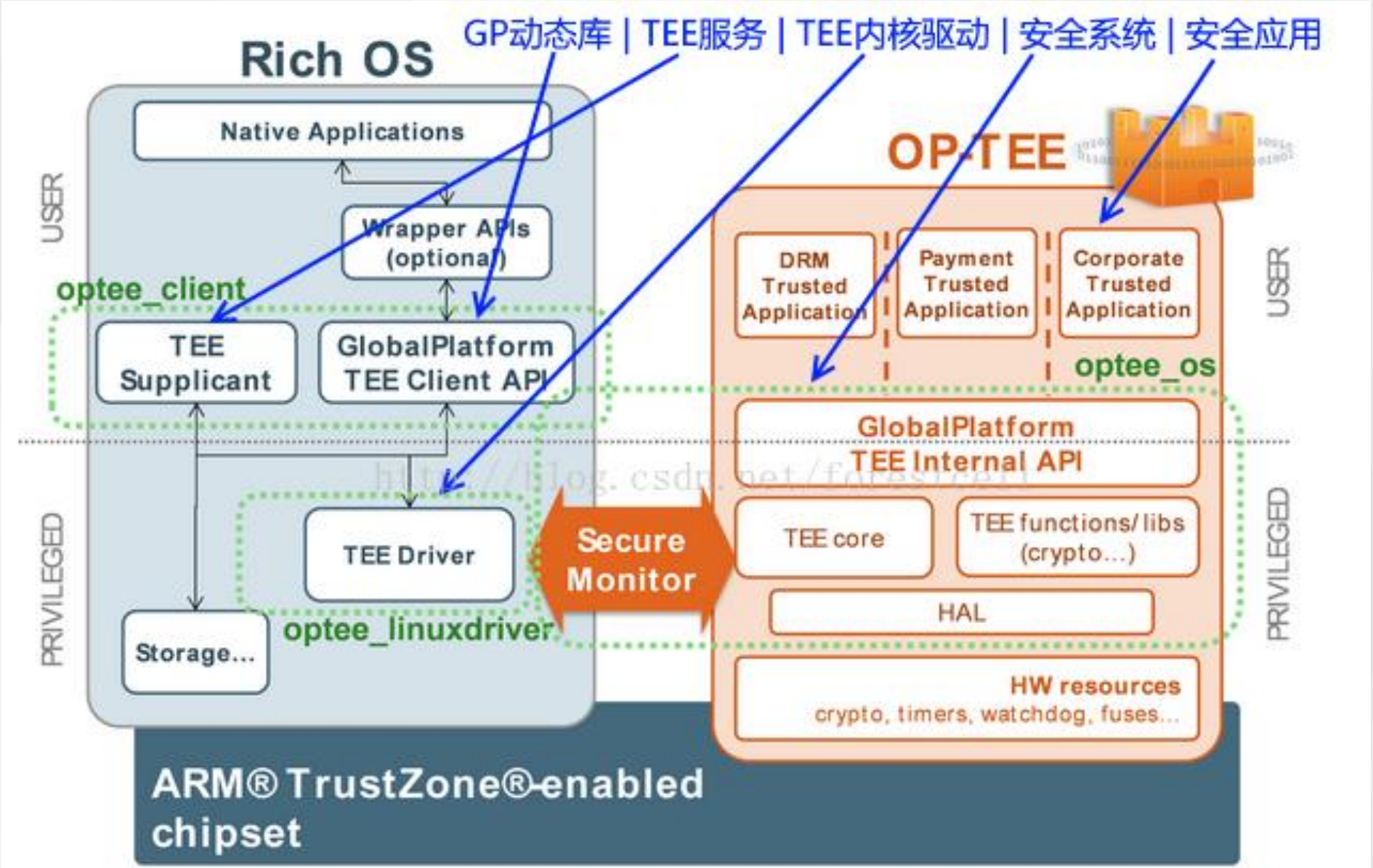


硬件安全API（Hardware security APIs）

- **ARM TrustZone**

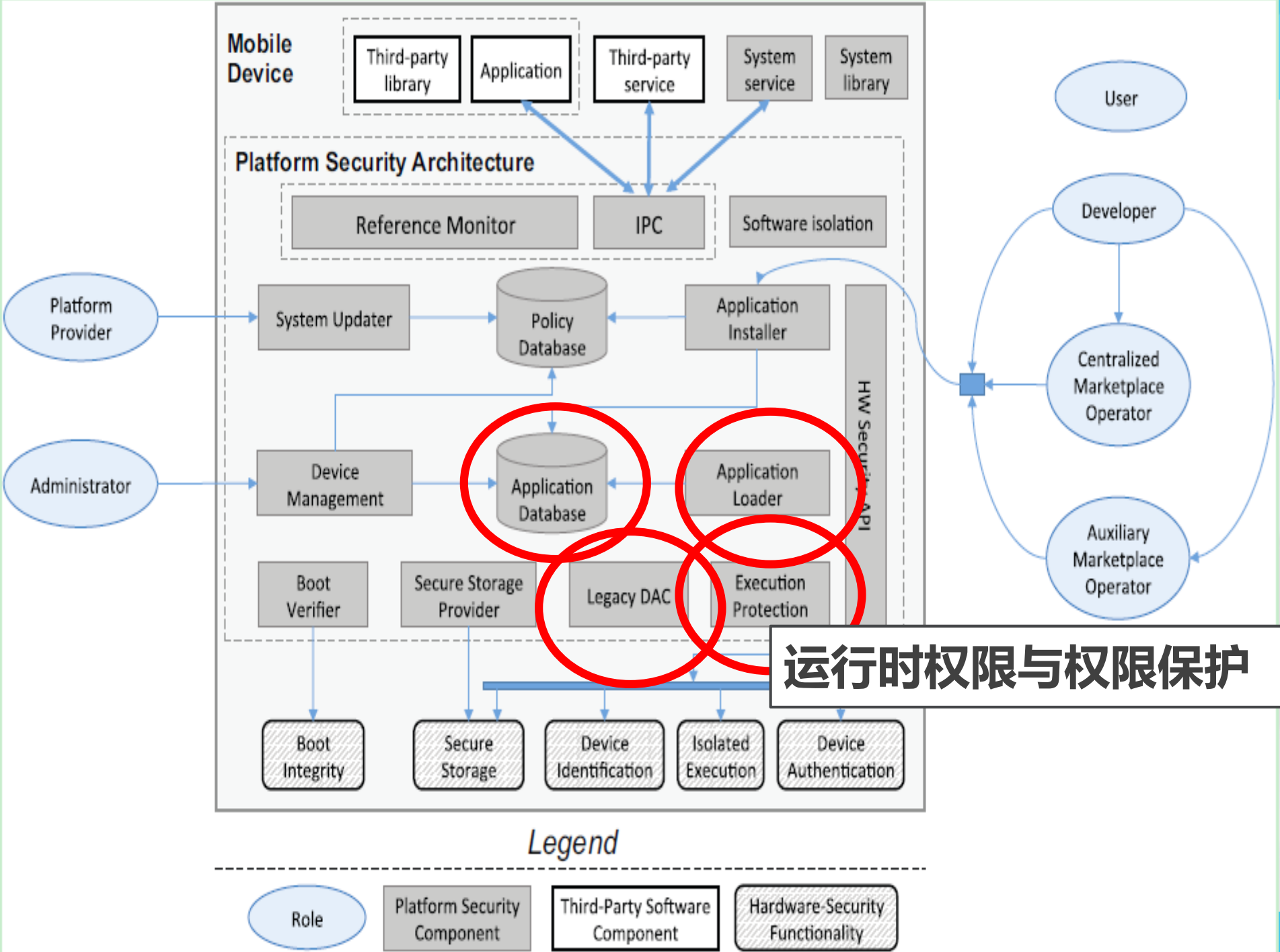
需要保密的操作在安全世界执行（如指纹识别、密码处理、数据加解密、安全认证等）	其余操作在非安全世界执行（如用户操作系统、各种应用程序等）

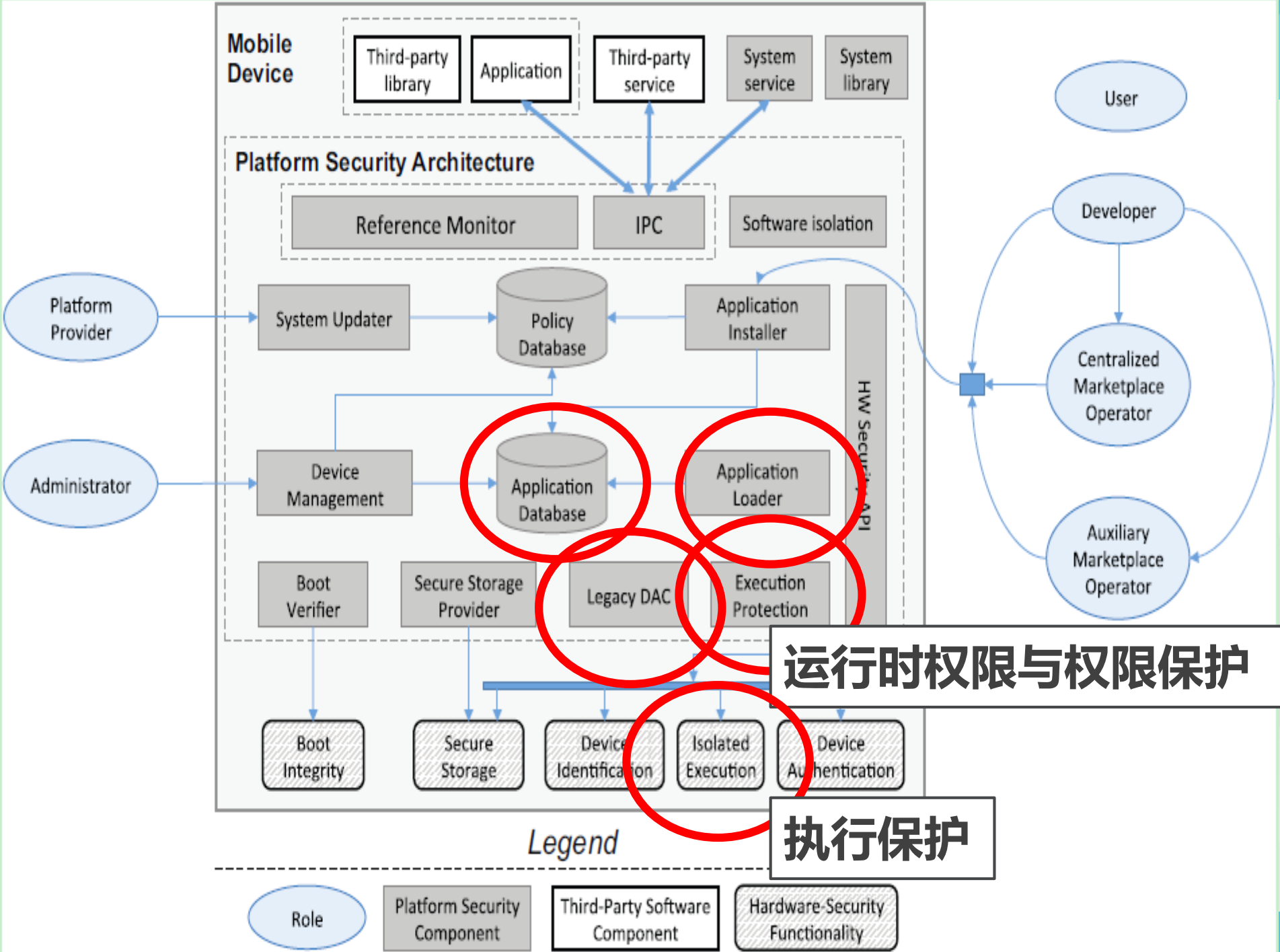


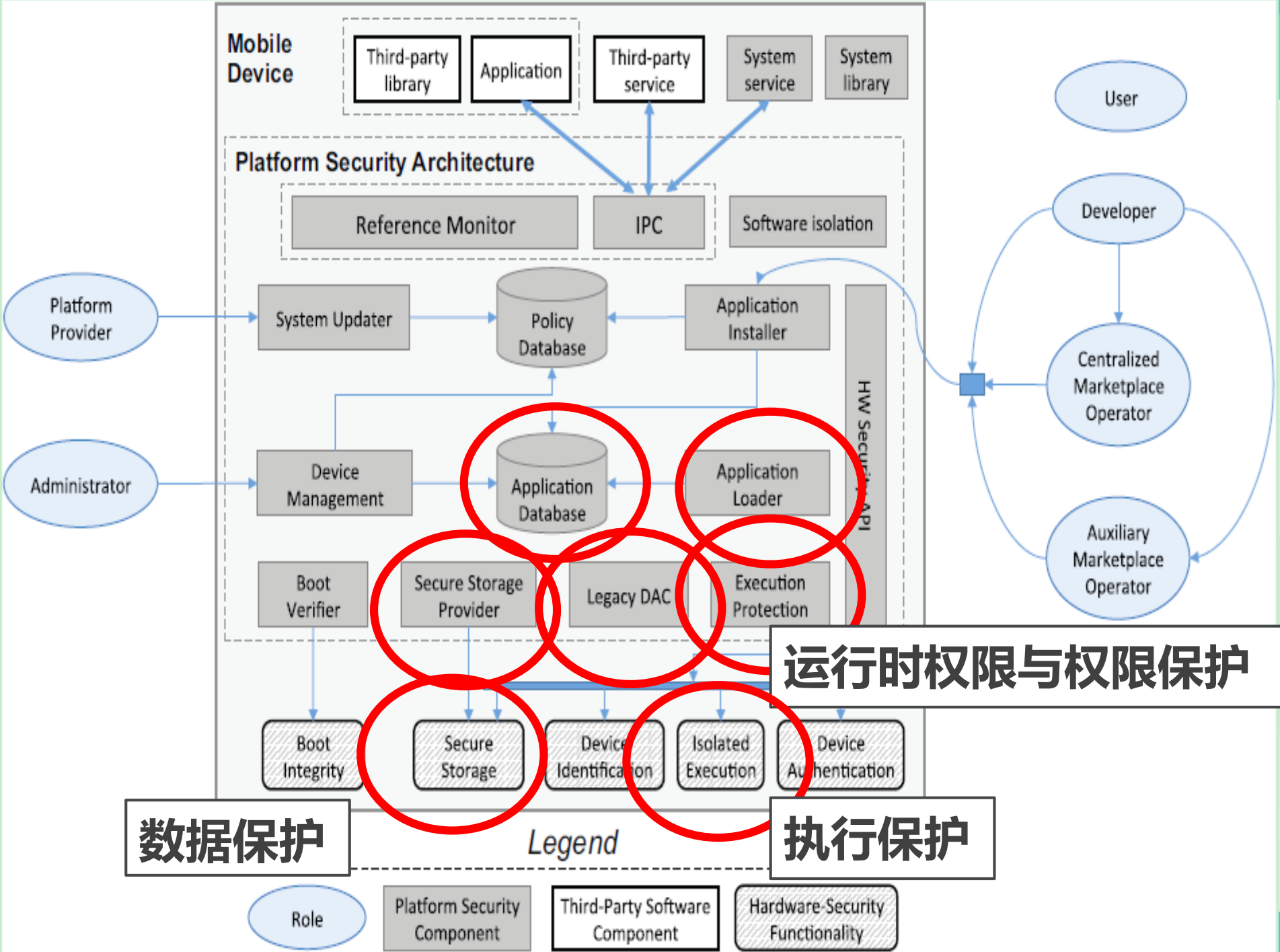

GP动态库 | TEE服务 | TEE内核驱动 | 安全系统 | 安全应用
Rich OS
Native Applications
Wrapper APIs (optional)
optee_client
TEE Supplicant
GlobalPlatform TEE Client API
TEE Driver
optee_linuxdriver
Storage...
USER
PRIVILEGED
Secure Monitor
OP-TEE
DRM Trusted Application
Payment Trusted Application
Corporate Trusted Application
optee_os
GlobalPlatform TEE Internal API
TEE core
TEE functions/ libs (crypto...)
HAL
HW resources
crypto, timers, watchdog, fuses...
ARM® TrustZone®-enabled chipset

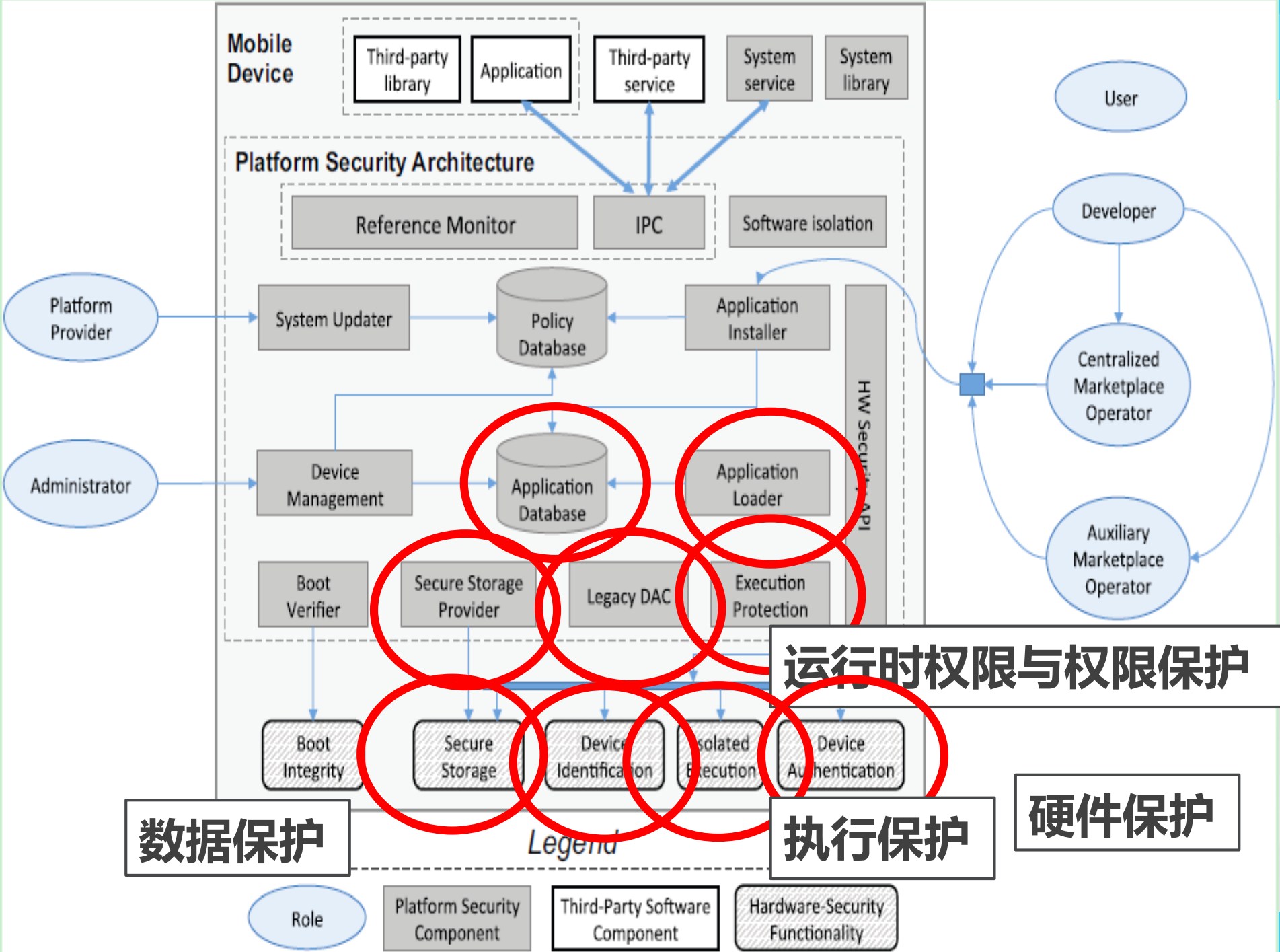
硬件安全API（Hardware security APIs）

- 如果设备支持当前的安全机制，**硬件安全API**（hardware security API）部件将为加载安全性关键代码的接口，以达到独立执行的目的
- 其他相似的硬件安全机制包括**设备认证**（device identification）和**设备授权**（device authentication）


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
运行时权限与权限保护
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
运行时权限与权限保护
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
执行保护
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
运行时权限与权限保护
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
数据保护
执行保护
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
运行时权限与权限保护
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
数据保护
执行保护
硬件保护
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality

2.3.4 平台管理

- 平台自身完整性和有关平台安全模型的设备管理概念
- 平台启动完整性（Platform boot integrity）
- 平台数据完整性（Platform data integrity）
- 平台更新（Platform updates）
- 设备管理（Device management）

平台启动完整性（Platform boot integrity）

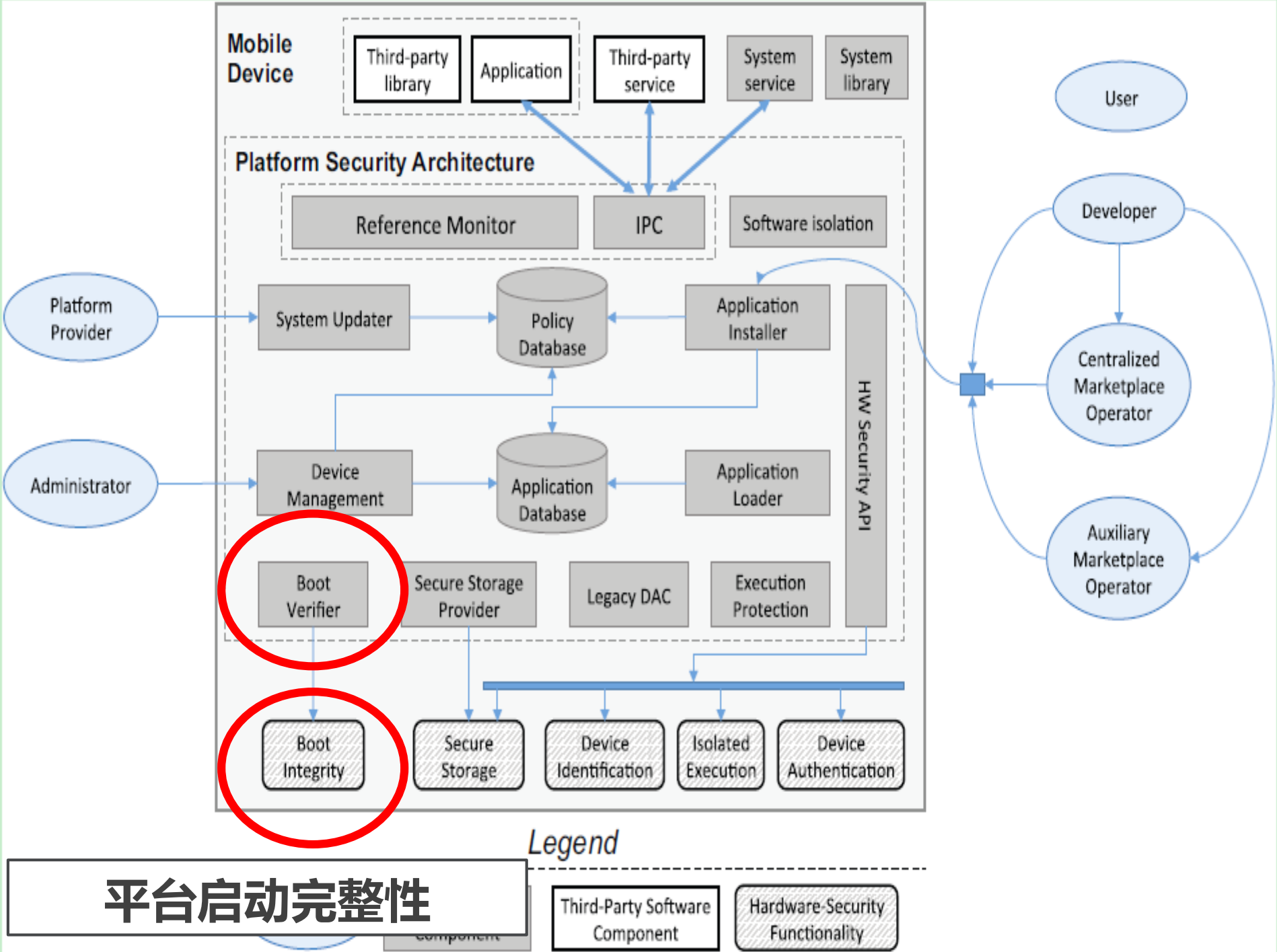
- 平台安全部件的完整性需要一定的保护机制
- 平台安全部件存储在一个能够长期存储的介质中，可通过外部接口连接（例如，USB端口）升级
- 如果一个敌手可以修改这些部件，他可以绕过访问控制策略等安全防护

平台启动完整性（Platform boot integrity）

- **方法1：硬件辅助的安全启动**：为了防止敌手篡改设备中的平台安全部件，厂商在设备启动过程中确保系统部件的完整性
- **平台验证器**（platform verifier）检查平台安全部件，根据设备厂商发布的参考和在设备硬件上不能改变的可信根的签名

平台启动完整性（Platform boot integrity）

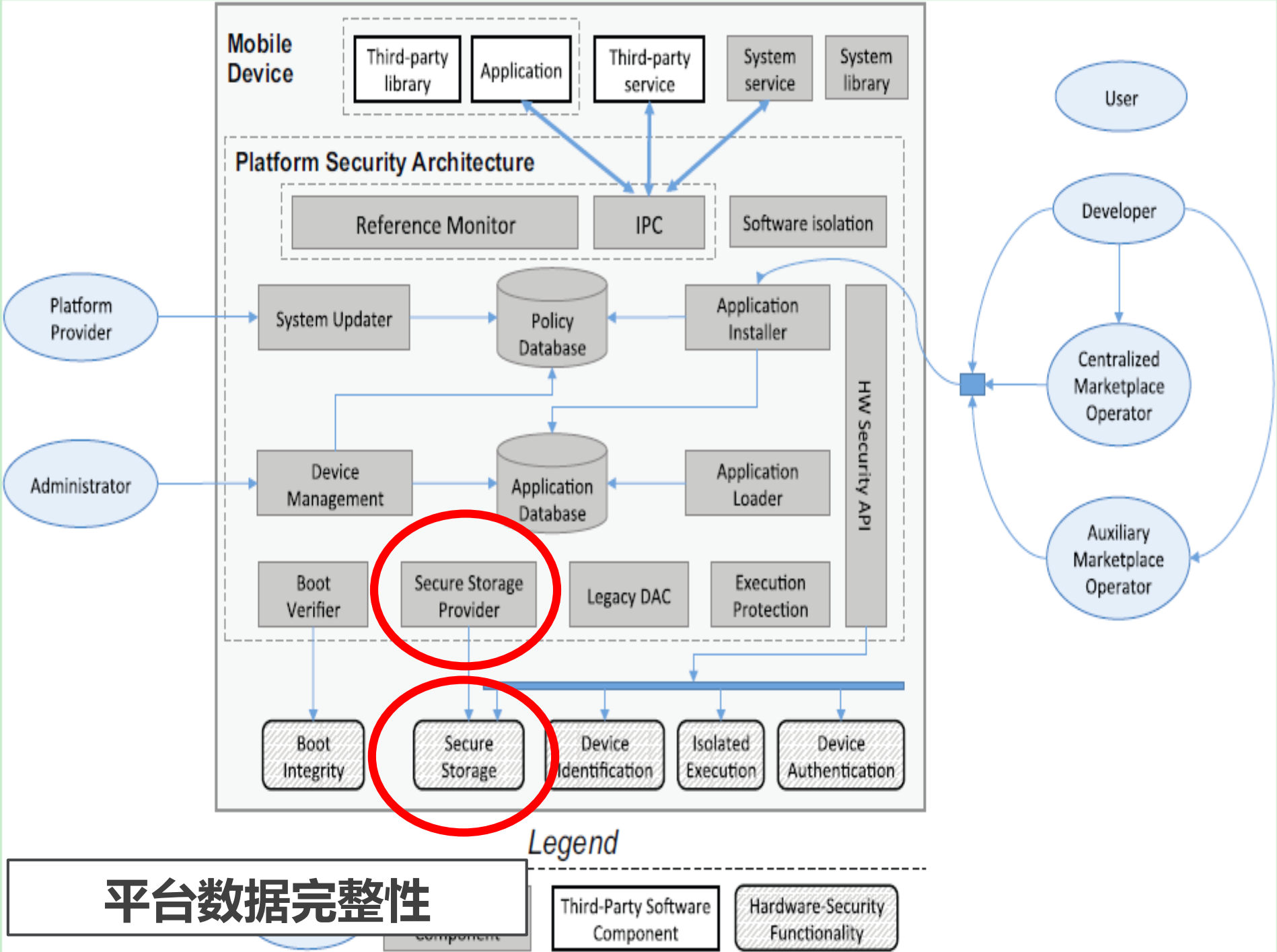
- 方法2：认证启动（authenticated boot）：设备厂商谨慎地允许开发者创建定制的操作系统版本，但是记录了已启动的平台部件完整性保护的硬件寄存器情况
- 攻击者不能够将新版本的系统反转回旧版本的系统


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Third-Party Software Component
Hardware-Security Functionality

平台启动完整性

平台数据完整性（Platform data integrity）

- 除了平台安全部件的完整性之外，还依赖于平台数据的安全性。例如策略数据库和应用数据库。如果敌手尝试修改这些数据库的内容，他将会分配给之前安装过的应用以任意的权限，或是修改已安装应用的行为
- 为了防止这种篡改，平台需要支持硬件辅助保护机制的安全存储（完整性保护）


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Third-Party Software Component
Hardware-Security Functionality

平台数据完整性

平台更新（Platform updates）

- 移动平台需要更新函数和修复潜在的漏洞
- 平台提供者为不同的系统部件发布更新。在移动设备上，**系统更新**（system updater）部件使用可信根和策略数据库中的系统更新策略授权给系统更新
- 当更新合理时，系统更新改写了操作系统映像的一部分。在一些平台中，系统更新是应用安装实施的一部分。

平台更新（Platform updates）

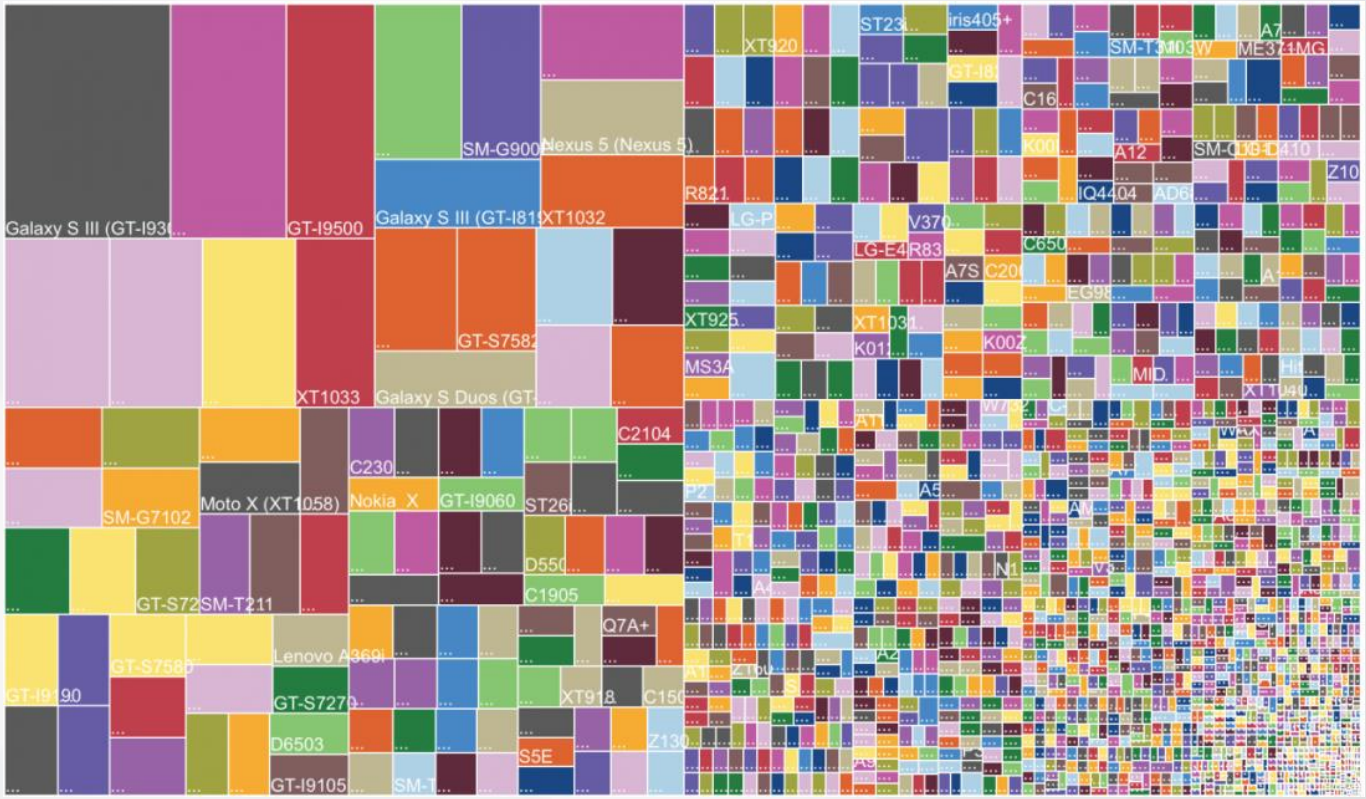
- 一个看起来无害的Google Chrome移动版本的升级，实际上是一种恶意软件，目的是窃取用户的财务信息和其他个人私密数据等。该恶意软件通过提醒用户2015年出现的 CTB Locker以及Critroni勒索软件的危害

平台更新（Platform updates）

平台更新的问题是什么?

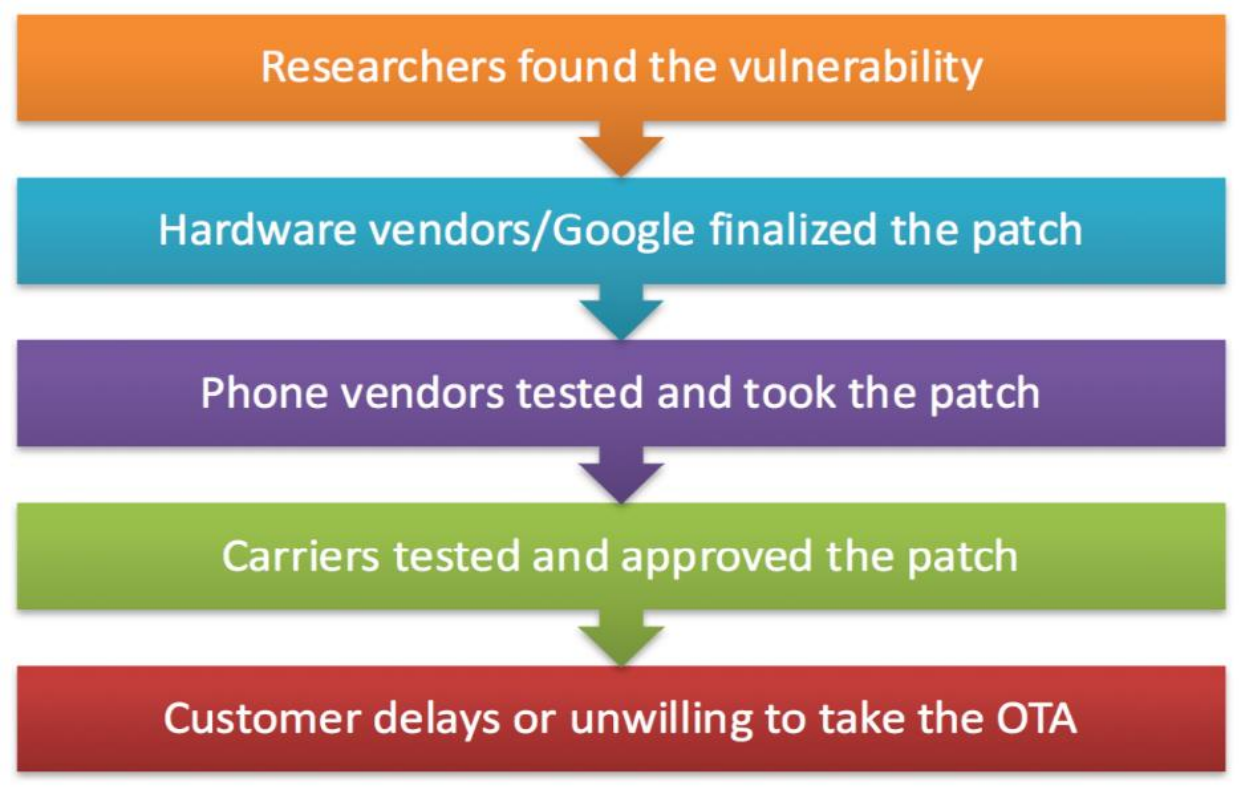
平台更新（Platform updates）

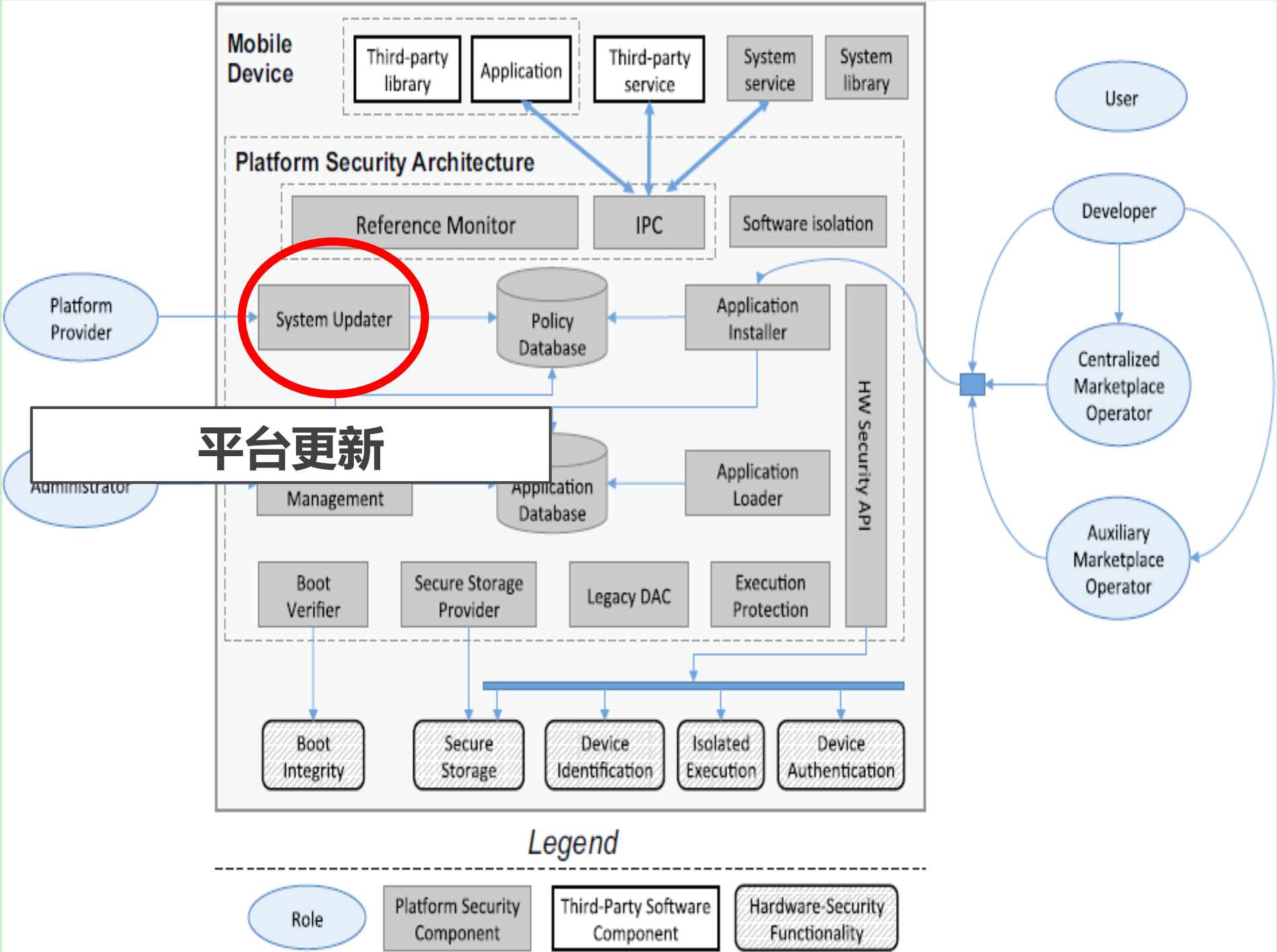
- 安卓的碎片化带来的更新问题
  - 长时间的更新 → Third-party



平台更新（Platform updates）

- 安卓的碎片化带来的更新问题
  - 长时间的更新 → Third-party




Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
平台更新
Administrator
Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Boot Verifier
Secure Storage Provider
Legacy DAC
Execution Protection
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality

设备管理（Device management）

- 管理员可以给移动设备发送设备管理命令。这些指令通过**设备管理**（device management）部件使用策略数据库中的可信根来确认。
- 可安装新的应用、移除已安装的应用、或在策略数据库中增加或移除新的可信根并且控制用户能够安装的应用类型。
- 远程管理员可以**修改特定的系统设置**，例如，授权PIN代码保护设备，或设置设备PIN的最短可接受的长度。这些策略的改变都存储在策略数据库中

设备管理（Device management）

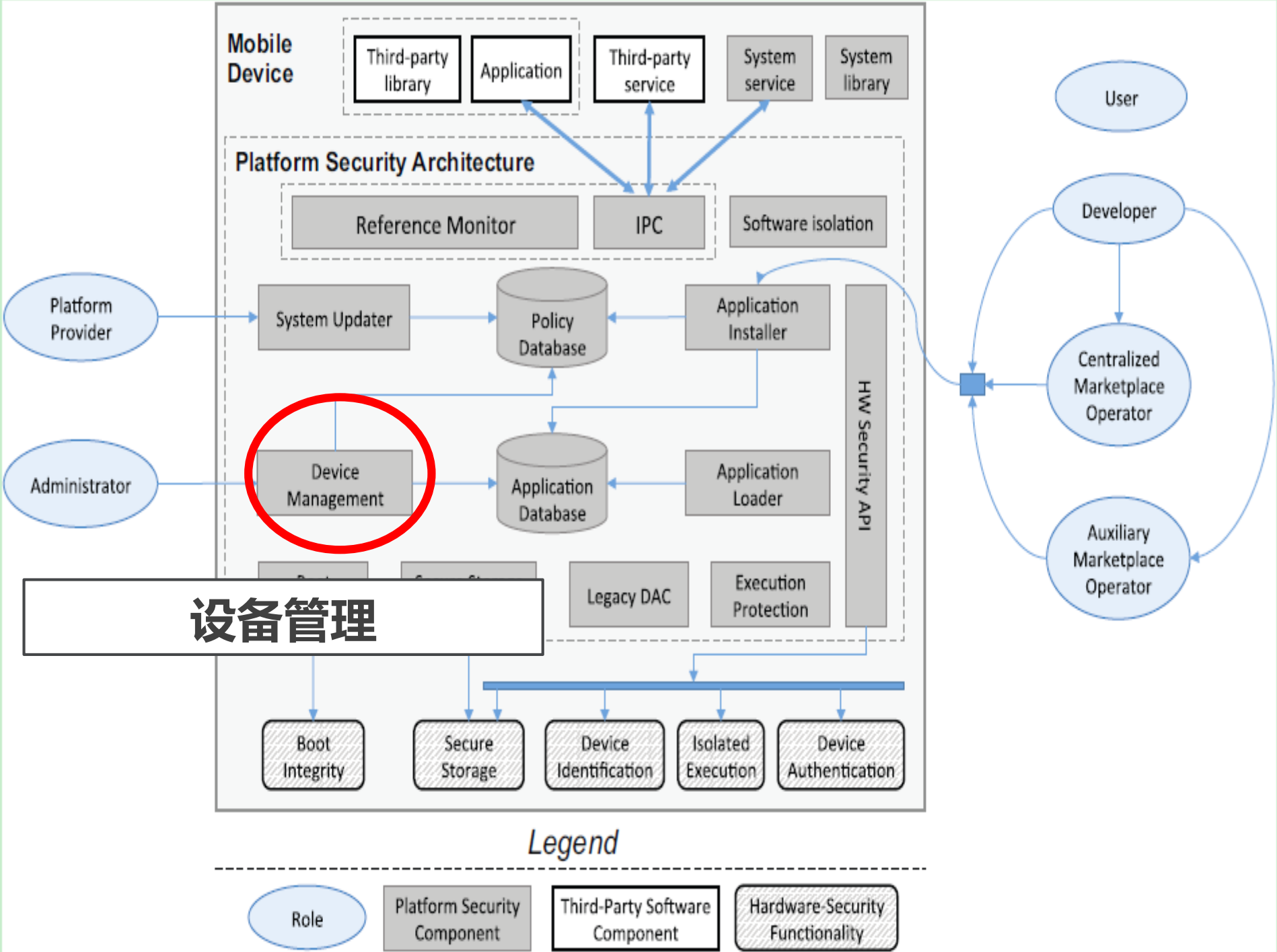
如何保证远程设备管理的安全呢?

设备管理（Device management）

如何保证远程设备管理的安全呢?

——不公开的协议?

——认证管理?


Mobile Device
Third-party library
Application
Third-party service
System service
System library
User
Platform Security Architecture
Reference Monitor
IPC
Software isolation
Developer
Platform Provider
System Updater
Policy Database
Application Installer
HW Security API
Centralized Marketplace Operator
Administrator
Device Management
Application Database
Application Loader
Auxiliary Marketplace Operator
Legacy DAC
Execution Protection
设备管理
Boot Integrity
Secure Storage
Device Identification
Isolated Execution
Device Authentication
Legend
Role
Platform Security Component
Third-Party Software Component
Hardware-Security Functionality

设备管理（Device management）

思考：用户信息（如硬件设备等）被唯一确定带来的问题

第二章 移动安全模型

(第二部分)